MINOR PROJECT - 1

Cybersecurity Risk Assessment Framework for Small Businesses

Submitted by

Ananta Pratap

1. Introduction

1.1 Background

In the present digital economy, Small and Medium Enterprises (SMEs) cannot do without information technology in their day to day activities such as managing customers, financial activities, communication and storage of information. Nevertheless, even though more SMEs are becoming digital, most of them do not have strong cybersecurity measures. This makes them such prime targets of cybercriminals.

According to the reports presented by the organizations like IBM and Verizon, it is noted that a high proportion of cyberattacks targets small businesses because of the low expenses on security measures and the ignorance of cybersecurity-related factors.

SMEs do not always have IT security teams, formal policies, and nonstop monitoring, as it is the case with big corporations. Consequently, a single cyber event can lead to major losses of money, image or total destabilization of business.

1.2 Problem Statement

Despite the existence of different cybersecurity frameworks, the majority of them target large companies and may be difficult to apply, resource-intensive, and complex to other companies (especially SMEs).

As an illustration, the National Institute of Standards and Technology Cybersecurity Framework is full of detailed recommendations, but it might involve technical knowledge and financial funding that small businesses are unable to afford.

Thus, there is a necessity of a simplified, scalable, and affordable cybersecurity risk assessment framework to be used by SMEs in particular.

1.3 Objectives of the Study

The major goals of this project are:

- To determine the prevailing cybersecurity threats to SMEs.
- To formulate a simplified model of risk assessment of cybersecurity based on the existing models.
- To develop a risk assessment measure to prioritize threats with regards to probability and severity.
- To recommend effective mitigation measures that will be appropriate to SMEs.
- To test the proposed model with the case-based analysis.

1.4 Scope of the Study

The research will dwell on the small and medium enterprises in the retail sector, accounting service sector and service industries. The framework is tailored to those organizations that have few cybersecurity systems and financial resources.

Penetration testing and live vulnerability scanning are not a part of the study. Rather, it focuses on logical risk assessment and risk mitigation strategy.

2. Literature Review

2.1 Cybersecurity Threats in Small and Medium Enterprises (SMEs).

Most importantly, Small and Medium Enterprises (SMEs) are emerging as popular targets of cyberattacks. Lack of financial and technical capabilities exposes many SMEs to external and internal threats because many of them do not have structured cybersecurity policies.

Verizon research reports reveal that a large percentage of data breaches are related to small businesses, which are mostly caused by a human factor and insufficient security measures. Equally, research conducted by IBM demonstrates that phishing and ransomware attacks are the most widespread to SMEs.

The various cybersecurity threats in SMEs are:

1. Phishing Attacks: Phishing refers to spam emails or messages that are aimed at deceiving employees into divulging confidential information like logins or other financial details. The awareness training of cybersecurity is especially low in SMEs.
2. Ransomware Attacks: Ransomware is used to encrypt business information to be paid to be decrypted. One of them, the WannaCry attack, took advantage of insecure systems and impacted thousands of organizations across the globe. Those SMEs that have obsolete software and poor backup systems have high risks.
3. Insider Threats: Insider threats can either be malicious (malicious employees), or accidental (lackadaisical actions). Absence of role-based access control and monitoring make it vulnerable.
4. Lax Authentication and Password Policies: The practices of Multi-Factor Authentication (MFA) and weak passwords are not implemented in many SMEs, which makes them vulnerable to brute-force and credential-stuffing attacks.
5. Unprotected Software and System Vulnerabilities: When software is not updated on a regular basis, systems become vulnerable to known vulnerabilities.

2.2 Current Cybersecurity Frameworks

Some of the developed cybersecurity models offer systematic methods of dealing with cyber threats.

2.2.1 NIST Cybersecurity Framework

The National Institute of Standards and Technology (NIST) Cybersecurity Framework is very popular and it is composed of five basic functions:

Identify

Protect

Detect

Respond

Recover

The framework offers detailed risk management directions but might be complicated to small business having little technical skills.

2.2.2 ISO/IEC 27001

The international standard of standardization ISO/IEC 27001 standard is aimed at defining an Information Security Management System (ISMS). It focuses on risk evaluation, policy writing, and continuous enhancement.

Although ISO 27001 is very powerful, it has formal certification schemes, documents, audits, and compliance expenses, which are simply not within the means of SMEs.

2.3 Research Gap

Current frameworks offer powerful cybersecurity governance frameworks that are commonly targeted at medium-to-large companies. SMEs require:

Streamlined implementation procedures.

Lower-cost solutions

Less documentation load

Measured and obvious risk scores.

Hence, it is necessary to develop a customized model of cybersecurity risk assessment that will not complicate the existing frameworks but will be effective.

2.4 Reason behind the proposed Framework

According to the analysis of the available literature, it is clear that exposure to cyber risks is high in SMEs, and they do not have structured appraisal tools. The proposed framework of this project is going to:

Modify basic guidelines of NIST.

Make it easier to analyze risks through a quantitative scoring model.

Give viable mitigation measures that are applicable to SMEs.

This fills the gap between theoretical framework and actual SME needs.

3. Possible Cybersecurity Risk Assessment Framework to SMEs

3.1 Research Statement: The Presented Framework

A risk assessment model is created based on the analysis of existing standards including the National Institute of Standards and Technology Cybersecurity Framework, to have a simplified and scalable risk assessment model of the Small and Medium Enterprises (SMEs). The suggested framework will be:

Simple to implement

Cost-effective Measurable Flexible to the various business types

The framework has six systematic steps where SMEs are able to identify, assess and mitigate cybersecurity risks systematically.

3.2 Proposed Framework Structure

The framework is carried out in stages:

Step 1: Asset Identification

The first step is that SMEs have to determine and categorize their most important digital assets.

Examples of assets:

Customer databases

Financial records

Employee information

Email systems

Cloud storage platforms

Payment processing systems

The assets are to be classified as:

High value

Medium value

Low value

This assists in prioritizing the protection efforts.

Step 2: Threat Identification

Having figured out the assets, it should list potential threats. Common SME threats include:

Phishing attacks

Ransomware

Insider misuse

Malware infections

Unauthorized access

Threat identification aids in the knowledge of potential sources of attack.

Step 3: Vulnerability Assessment

During this phase, SMEs evaluate vulnerabilities that can enable threats to abuse systems. Vulnerabilities examples:

Outdated software

Weak password policies

None Multi-Factor Authentication (MFA)

Lack of firewall

No regular backups

This is a step that identifies the degree of exposure of the organization.

Step 4: Risk Scoring and Evaluation

A quantitative risk formula is applied, which is developed in a hierarchical fashion:

Risk Score= Likelihood x Impact.

Where: The likelihood is used to measure the likelihood of occurrence (scale 1-5). The extent of the damage is measured by impact (scale 1-5). In this way of quantitative approach, risk is measurable and can be prioritized more easily. (A comprehensive risk matrix can be discussed in the following part of the paper.)

Step 5: Risk Prioritization

Calculated risks are divided into:

Low Risk

Medium Risk

High Risk

Critical Risk

Critical risks have to be mitigated at once whereas low risks can be observed. This enables the SMEs to utilise limited resources.

Step 6: Implementation of Mitigation and Control

Once prioritization is administered, relevant controls are chosen, including:

Firewalls

Multi-Factor Authentication

Training on employee awareness.

Regular data backups

Patch management policies

The strategies of mitigation are determined by the risk severity and business viability.

3.3 Framework Flow Structure

The flow chart of the framework can be illustrated as:

Asset Identification

Threat Identification

Vulnerability

Assessment Risk Calculation

Risk Prioritization

Mitigation Planning

Continuous Monitoring

This hierarchy keeps the cybersecurity posture up to date.

3.4 Major Characteristics of the proposed Framework

The proposed model is unlike the frameworks of big enterprises in the following ways: Simplified scale of scoring (1-5 scale)

Light requirements in documentation

Make investments in realistic SME controls

Mitigation planning that is price sensitive

Applicable in other industries.

4. Risk Evaluation Metric and Risk Matrix Design

4.1 Introduction to Risk Evaluation

Risk evaluation refers to the process of identifying the severity of the identified threats depending on their likelihood of happening and the impact that may be caused to the business.

The model proposed employs a quantitative scoring technique that is based on the set of principles of risk management concepts set by the National Institute of Standards and Technology framework but simplified to be applicable to SMEs.

The aim is to develop an easily applicable risk ranking system that is measurable.

4.2 Risk Calculation Formula

It is calculated as below:

isk Score = Likelihood × Impact

Where: Likelihood = Probability of occurrence of a threat.

Impact = Degree of damage in the event that the threat occurs. The two parameters are scored out of 1 to 5.

4.3 Likelihood Scale Definition

Score	Likelihood Level	Description
1	Rare	Occurs very infrequently
2	Unlikely	Possible but not common
3	Moderate	Occasional occurrence
4	Likely	Occurs frequently
5	Very Likely	Highly frequent or expected

4.4 Impact Scale Definition

Score	Impact Level	Description
1	Insignificant	Minor inconvenience, no loss
2	Low	Small operational disruption
3	Moderate	Temporary business interruption
4	High	Major financial or reputational damage
5	Severe	Business shutdown or major data breach

4.5 Risk Classification Levels

Since both values range from 1 to 5, the maximum risk score is 25.

Risk levels are categorized as follows:

Risk Score Range	Risk Level	Action Required
1–5	Low	Monitor periodically
6–10	Medium	Improve controls
11–15	High	Immediate mitigation required
16–25	Critical	Urgent action and priority treatment

4.6 Sample Risk Evaluation Table

Below is a sample application of the model:

Threat	Likelihood	Impact	Risk Score	Risk Level
Phishing	5	4	20	Critical
Ransomware	4	5	20	Critical
Insider Threat	3	4	12	High
Weak Passwords	5	3	15	High
Unpatched Software	4	4	16	Critical

This structured table allows SMEs to visually identify their most urgent threats.

4.7 Risk Matrix Representation (Conceptual)

The risk matrix can be visualized as a 5×5 grid where:

- The horizontal axis represents Likelihood (1–5)
- The vertical axis represents Impact (1–5)

Higher values in the upper-right corner represent critical risks.

This visual representation improves decision-making clarity for management.

4.8 Advantages of the Proposed Risk Metric

1. Simple mathematical model
2. Easy to apply without technical expertise
3. Allows prioritization with limited resources
4. Scalable across different SME types
5. Provides measurable risk comparison before and after mitigation

5. Case Study and Model Validation

5.1 Purpose of Validation

In order to verify the effectiveness of the proposed Cybersecurity Risk Assessment Framework, the model is implemented to two hypothetical Small and Medium Enterprises (SMEs). It is aimed at showing the process of risk identification, scoring and prioritization, as well as mitigation strategies that can be used to reduce risks.

5.2 Case Study 1: Small Retail Business.

Business Profile

15 employees

Utilizes billing software based on the cloud.

Customers payment information is stored in stores.

None of the specific IT security personnel.

Basic antivirus installed

None No Multi-Factor Authentication (MFA)

Irregular data backups

Step 1: Asset Identification

Critical assets identified: Customer database

Payment processing system

Employee credentials

Email system

Step 2: Threat Identification

Major threats include:

Phishing emails

Ransomware attacks

Weak password exploitation

Malware infections

Step 3: Risk Evaluation (Before Mitigation)

Threat	Likelihood	Impact	Risk Score	Risk Level
Phishing	5	4	20	Critical
Ransomware	4	5	20	Critical
Weak Passwords	5	3	15	High
Malware	4	3	12	High

Observation:

The business faces multiple Critical and High risks due to lack of structured security controls.

Step 4: Mitigation Implemented

- Enabled Multi-Factor Authentication
- Installed firewall
- Implemented weekly automated backups
- Conducted employee awareness training

Risk Evaluation (After Mitigation)

Threat	Likelihood	Impact	Risk Score	Risk Level
Phishing	3	4	12	High
Ransomware	2	5	10	Medium
Weak Passwords	2	3	6	Medium
Malware	2	3	6	Medium

Result:

Overall risk exposure reduced significantly. Critical risks were eliminated.

5.3 Case Study 2: Small Accounting Firm

Business Profile

- 10 employees
- Stores financial and tax records
- Uses local server storage
- Outdated operating system
- No encryption

Step 1: Asset Identification

Critical assets:

- Client financial data
- Tax records
- Internal financial systems

Step 2: Threat Identification

- Ransomware
- Insider misuse
- Unauthorized external access
- Data breach

Risk Evaluation (Before Mitigation)

Threat	Likelihood	Impact	Risk Score	Risk Level
Ransomware	4	5	20	Critical
Insider Threat	3	4	12	High
Unauthorized Access	4	4	16	Critical

Threat	Likelihood	Impact	Risk Score	Risk Level
Data Breach	3	5	15	High

Mitigation Implemented

- Updated operating systems
- Encrypted sensitive data
- Role-based access control
- Regular system patching
- Activity logging

Risk Evaluation (After Mitigation)

Threat	Likelihood	Impact	Risk Score	Risk Level
Ransomware	2	5	10	Medium
Insider Threat	2	4	8	Medium
Unauthorized Access	2	4	8	Medium
Data Breach	2	5	10	Medium

5.4 Comparative Analysis

Both case studies demonstrate that:

- Structured risk identification improves visibility.
- Quantitative scoring helps prioritize threats.
- Implementing cost-effective controls significantly reduces risk levels.
- Critical risks can be downgraded to Medium with proper controls.

This validates that the proposed framework is practical, scalable, and effective for SMEs.

6.Best Practices and Risk Mitigation Strategies of SMEs

Risk mitigation refers to the implementation of security measures aimed at reducing the likelihood and impact of cybersecurity threats. Since SMEs often operate with limited financial and technical resources, mitigation strategies must be practical, affordable, and easy to implement.

The proposed framework emphasizes preventive and corrective controls aligned with recommendations from organizations such as the National Institute of Standards and Technology.

6.2 Technical Security Controls

Technical controls involve the use of software and hardware solutions to protect organizational systems and data.

Firewall Implementation

Firewalls monitor incoming and outgoing network traffic and prevent unauthorized access to internal systems.

Multi-Factor Authentication (MFA)

MFA requires users to verify identity using multiple authentication factors, significantly reducing credential-based attacks.

Antivirus and Endpoint Protection

Endpoint security solutions detect malware, ransomware, and suspicious activities across organizational devices.

Data Encryption

Encryption protects sensitive information by converting data into unreadable formats accessible only through authorized keys.

Regular Software Updates and Patch Management

Updating operating systems and applications prevents exploitation of known vulnerabilities.

Administrative Security Controls

Administrative controls focus on policies, procedures, and employee awareness.

Employee Cybersecurity Training

Employees should be trained to:

- Recognize phishing emails
- Avoid suspicious downloads
- Follow password security practices

Human error remains one of the leading causes of cyber incidents.

Access Control Policies

Role-Based Access Control (RBAC) ensures employees access only the information necessary for their roles.

Incident Response Plan

SMEs should establish procedures for:

- Detecting incidents
- Reporting breaches
- Recovering compromised systems

6.4 Network Security Measures

Secure Wi-Fi Configuration

Businesses should:

- Use WPA3 encryption
- Change default router credentials
- Restrict guest network access

Virtual Private Network (VPN)

VPNs secure remote access by encrypting communication between users and company networks.

Intrusion Detection Systems (IDS)

IDS solutions monitor abnormal network behavior and provide early threat detection.

6.5 Data Protection and Backup Strategies

Regular data backup is essential for business continuity.

The **3-2-1 Backup Rule** is recommended:

- Maintain 3 copies of data
- Store on 2 different media types
- Keep 1 copy offsite or in cloud storage

This strategy minimizes damage from ransomware attacks.

6.6 Cybersecurity Best Practices for SMEs

Based on the proposed framework, SMEs should adopt the following best practices:

1. Enable Multi-Factor Authentication across all systems.
2. Conduct periodic cybersecurity risk assessments.
3. Maintain regular software updates.
4. Limit administrative privileges.
5. Monitor network activity continuously.
6. Perform routine data backups.
7. Establish cybersecurity awareness programs.
8. Develop incident response and recovery plans.

6.7 Expected Outcomes of Mitigation

Implementation of these strategies results in:

- Reduced probability of cyberattacks
- Faster incident response
- Improved data protection
- Enhanced organizational resilience
- Lower financial and reputational risk

7.Conclusion

The risk of the cybersecurity threat has become an issue of concern among the Small and Medium Enterprise (SMEs) because of the growing level of digital reliance and inadequate security infrastructure. In contrast to the large organizations, SMEs tend to have no specific cybersecurity background, well-designed policies, and money to introduce complex security systems.

This project offered a simplified Cybersecurity Risk Assessment Framework, specific to the SME. The model developed, inspired by the conceptual advice through the accepted standards like the National Institute of Standards and Technology Cybersecurity Framework, is geared towards practicality, cost-effectiveness, and simplicity of implementation.

The framework helps organizations to identify critical assets, identify possible threats, assess vulnerabilities and compute the risk level through a quantitative scoring system with the

likelihood and impact. The platform of risk assessment measure and prioritization strategy enables the small business enterprises to devote scarce resources to the risky areas effectively.

Case study validation showed that how the organization risk exposure can be mitigated through organized risk mitigation strategies (Multi-Factor Authentication, employee awareness training, periodic backups, system updates) can have a great impact in curbing organizational risk exposure. Its findings and results suggest that even the security controls that are of low costs can efficiently turn the critical security risks into manageable levels.

On the whole, the suggested framework will help fill the vacuum between complicated enterprise cybersecurity requirements and realistic small business demands. Through the model, the SMEs will be in a position to strengthen their cybersecurity positions, be able to withstand cyber threats, and be able to maintain continuity of their business in an ever-digitized landscape.

As the next step to enhance the SME cybersecurity management, the automation of risk assessment procedures and their connection with real-time monitoring systems can be enhanced in the future.

References

IBM. (2023). *Cost of a Data Breach Report 2023*. IBM. Retrieved from https://www.ibm.com/security/data-breach

Verizon. (2023). *Data Breach Investigations Report (DBIR)*. Verizon. Retrieved from https://www.verizon.com/business/resources/reports/dbir/

National Institute of Standards and Technology. (2018). *Framework for Improving Critical Infrastructure Cybersecurity*. National Institute of Standards and Technology (NIST). Retrieved from https://www.nist.gov/cyberframework

International Organization for Standardization. (2013). *ISO/IEC 27001 Information Security Management Systems*. International Organization for Standardization. Retrieved from https://www.iso.org

Kaspersky. (2022). *IT Security Risks for Small and Medium Businesses*. Kaspersky. Retrieved from https://www.kaspersky.com

Symantec Corporation. (2021). *Internet Security Threat Report*. Symantec. Retrieved from https://www.broadcom.com/symantec